

Juan Pablo de Legarreta

NETC 180 – Information Risk Management

Module Four Assignment

Security Controls

Keeping data secure requires implementing security controls. According to the Center for Internet Security, or CIS, there are 18 different Critical Security Controls. (CIS) These Critical Security Controls replaced the SANS Top 20 list, consolidating and updating the security controls. (CIS) The table below lists the controls directly from the CIS website:

CIS 18 Critical Security Controls		
CIS Control 1 Inventory and Control of Enterprise Assets	CIS Control 2 Inventory and Control of Software Assets	CIS Control 3 Data Protection
CIS Control 4 Secure Configuration of Enterprise Assets & Software	CIS Control 5 Account Management	CIS Control 6 Access Control Management
CIS Control 7 Continuous Vulnerability Management	CIS Control 8 Audit Log Management	CIS Control 9 Email and Web Server Protections
CIS Control 10 Malware Defenses	CIS Control 11 Data Recovery	CIS Control 12 Network Infrastructure Management
CIS Control 13 Network Monitoring and Defense	CIS Control 14 Security Awareness and Skills Training	CIS Control 15 Service Provider Management
CIS Control 16 Application Software Security	CIS Control 17 Incident Response Management	CIS Control 18 Penetration Testing

Each of these controls covers different functions in the National Institute of Standards and Technology's Cybersecurity Framework 2.0: Identify, Protect, Detect, Respond, Recover, and Govern. (NIST, p. 3) The NIST CSF 2.0 is a standard framework that helps organizations manage cybersecurity risks. (NIST, Abstract p. i) Each of the six core functions is crucial to an organization's cybersecurity policy, and choosing the right related security controls is critical.

Security Control Selection

Selecting the right security controls depends on the data type, its classification level, and its usage in the company. Though specifics on data usage were not extensively explained in the business case study, the normal function and usage of these data categories is an appropriate baseline to choose the most appropriate security control to implement. Choosing security controls to implement is a function of CSF 2.0's Core Function, Govern, which is part of an organization's cybersecurity risk management strategy. (NIST, p. 3) The other Core Functions are connected to the different CIS Controls and helped to inform their selection. The table below shows a the security controls selected as the most appropriate for each of the data groups:

Data Type	Classification	Most Appropriate Security Control
HR Data	Restricted	CIS Control 4 – Secure Configuration of Enterprise Assets and Software
Customer Data	Restricted	CIS Control 3 – Data Protection
Financial Data	Confidential	CIS Control 6 – Access Control Management
Operational Data	Restricted	CIS Control 4 – Secure Configuration of Enterprise Assets and Software
Compliance Data	Confidential	CIS Control 6 – Access Control Management

Security Control Justification

1. HR Data: CIS Control 4 – Secure Configuration of Enterprise Assets and Software

HR Data is comprised of personal data of RG Enterprise's employees. This data includes employees' PII, payroll, and financial data. The protection of HR data is of the utmost importance, and this data is classified as Restricted. Protect is one of the CSF's Core Functions, and a key part of any cybersecurity risk management strategy. (NIST, p. 4) With protection in mind, the most appropriate security control to implement for this data is CIS Control 4 – Secure Configuration of Enterprise Assets and Software. CIS Control 4 is used to “establish and maintain the secure configuration of enterprise assets (end-user devices, including portable and mobile; network devices; non-computing/IoT devices; and servers)

and software (operating systems and applications).” (“CIS Control 4: Secure Configuration of Enterprise Assets and Software”)

RG Enterprise most likely keeps its HR data stored locally, therefore hardening the security of its physical systems and networks along with its software would be an excellent start to keep this data protected and safe from outside threats. Additional security controls would be helpful to implement, but starting with CIS Control 4 is the most appropriate course of action.

2. Customer Data: CIS Control 3 – Data Protection

Customer Data is arguably the most sensitive data that RG Enterprises holds. Customer Data opens the door to a lot of different risks, with potential fallout that could hugely impact the company. Customer Data also has the strictest data classification: Restricted. Of all the security controls that handle data, the most appropriate security control for Customer Data is CIS Control 3 – Data Protection. CIS Control 3 is explained as a control to “develop processes and technical controls to identify, classify, securely handle, retain, and dispose of data.” (“CIS Control 3: Data Protection”) CIS Control 3 is quite important and falls under both the Identify and the Protect Core Functions of NIST’s CSF. (NIST, p. 3-4)

Processes to identify and classify data are incredibly important, as Customer Data could include not just PII but credit card information, purchase history and habits, maybe even usernames and passwords. Being able to identify the different subcategories of data and classify them would take a lot of burden off individual employees to ensure the security of this data. Additionally, securely handling and retaining data once it’s been identified and classified would help ensure that processes are in place to keep this data from being mishandled or leaked. Finally, the process of disposing of data is a key step in securely

handling Customer Data. While additional security controls are important to use with Customer Data, the most appropriate control is CIS Control 3.

3. Financial Data: CIS Control 6 – Access Control Management

Financial Data includes reports and information about budgets, sales, expenses, and other finances. This data holds a strict classification of Confidential, which requires isolating the data to only the few people who really need to access it. Keeping the data's access limited is of key importance to ensure its security, and thus the most appropriate security control to implement for this data type is CIS Control 6 – Access Control Management. CIS Control 6 is a security control that mainly uses “processes and tools to create, assign, manage, and revoke access credentials and privileges for user, administrator, and service accounts for enterprise assets and software.” (“CIS Control 6: Access Control Management”) CIS Control is part of the NIST CSF's Protect Core Function. (NIST, p. 4) Controlling the access credentials and privileges for internal and external users to specific data is a great way to keep the privacy of the financial data to the teams that need access to it as well as secure it from outside or malicious actors. This security control will help to isolate the data from prying eyes and make sure that only authorized users are able to access it. Cutting it off from users not authorized to access this data makes CIS Control 6 the most appropriate security control to implement for Financial Data.

4. Operational Data: CIS Control 4 – Secure Configuration of Enterprise Assets and Software

Operational Data includes data about different areas of RG Enterprise's operations and business functions, including inventory, materials, marketing, research, assets, and intellectual property. Operational Data is sensitive, especially the company's intellectual property, and is classified as Restricted, the strictest data classification. Since this data is

probably tracked and kept within the company's network and technology, the most appropriate security control to implement for this data type is CIS Control 4 – Secure Configuration of Enterprise Asset and Software. CIS Control 4 establishes secure configurations of enterprise assets and software, ensuring that the on-site network and assets are secure. (“CIS Control 4”) CIS Control 4 is a very important part of NIST's CSF Protect Core Function, as securing the place where the data is kept is a great first step to keep this data secure. (NIST, p. 4) It will also help as a springboard to other security controls that could further secure the company's Operational Data, making CIS Control 4 most appropriate.

5. Compliance Data – CIS Control 6 – Access Control Management

Compliance Data is a data type that includes legal information, such as copyrights, trademarks, permissions, taxes, incorporation papers, and other legal documentation. Given that it is classified as Confidential due to it not being required information for all employees to access or know about, the most appropriate security control to implement is CIS Control 6 – Access Control Management. CIS Control 6 is a part of the Protect Core Function of NIST's CSF. (NIST, p. 4) Since CIS Control 6 uses tools to manage access credentials and permissions for data, it can be used to ensure that only authorized users can access the Compliance Data. (“CIS Control 6”) CIS Control 6 would help to keep this data from being compromised from the outside or accidentally accessed by employees who should not be able to access this information. Though additional security controls would certainly be encouraged and useful to fully secure this data, ensuring that only the right users can access this information is a great first step to secure this data, making CIS Control 6 the most appropriate security control for Compliance Data.

Bibliography

Center for Internet Security. “The 18 CIS Controls.” *CIS*, 2024,

www.cisecurity.org/controls/cis-controls-list.

“CIS Control 3: Data Protection.” *CIS*, www.cisecurity.org/controls/data-protection.

“CIS Control 4: Secure Configuration of Enterprise Assets and Software.” *CIS*,

<https://www.cisecurity.org/controls/secure-configuration-of-enterprise-assets-and-software>

“CIS Control 6: Access Control Management.” *CIS*,

<https://www.cisecurity.org/controls/access-control-management>

National Institute of Standards and Technology. “The NIST Cybersecurity Framework (CSF)

2.0.” *The NIST Cybersecurity Framework (CSF) 2.0*, vol. 2.0, no. 29, 26 Feb. 2024,

nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf,

<https://doi.org/10.6028/nist.cswp.29>.